

CVE-2025-41358

IDOR

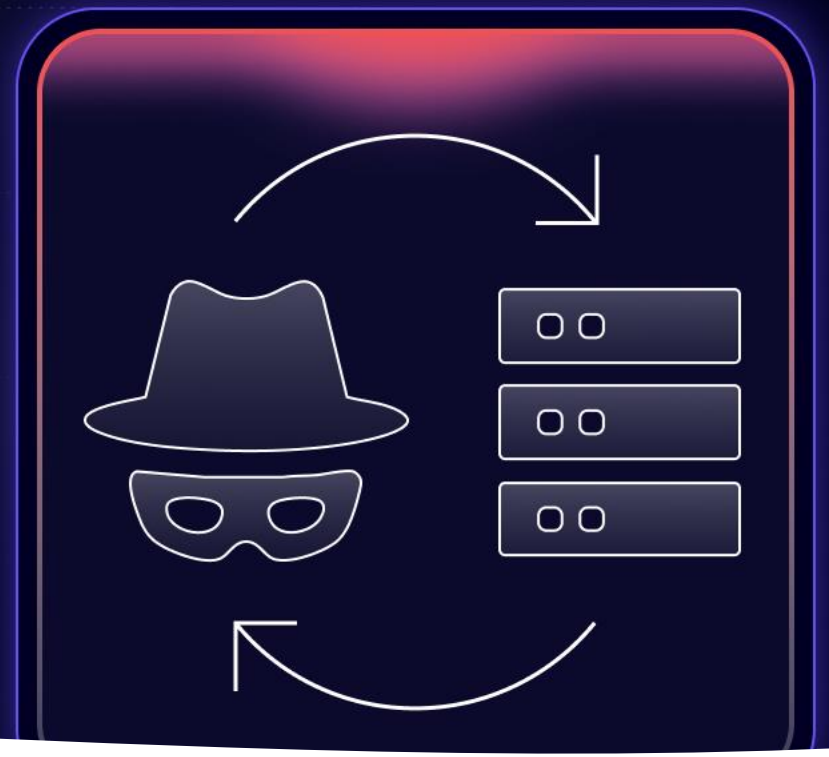
Insecure Direct Object Reference (IDOR)

Wiktor Leszczyński, Jan Malinowski, Antoni Łukasiewicz

Agenda

- Czym jest IDOR i gdzie leży problem?
- Jak działa to w praktyce?
- Skutki
- Jak skutecznie zapobiegać?
- Sesja Q&A

IDOR Vulnerabilities

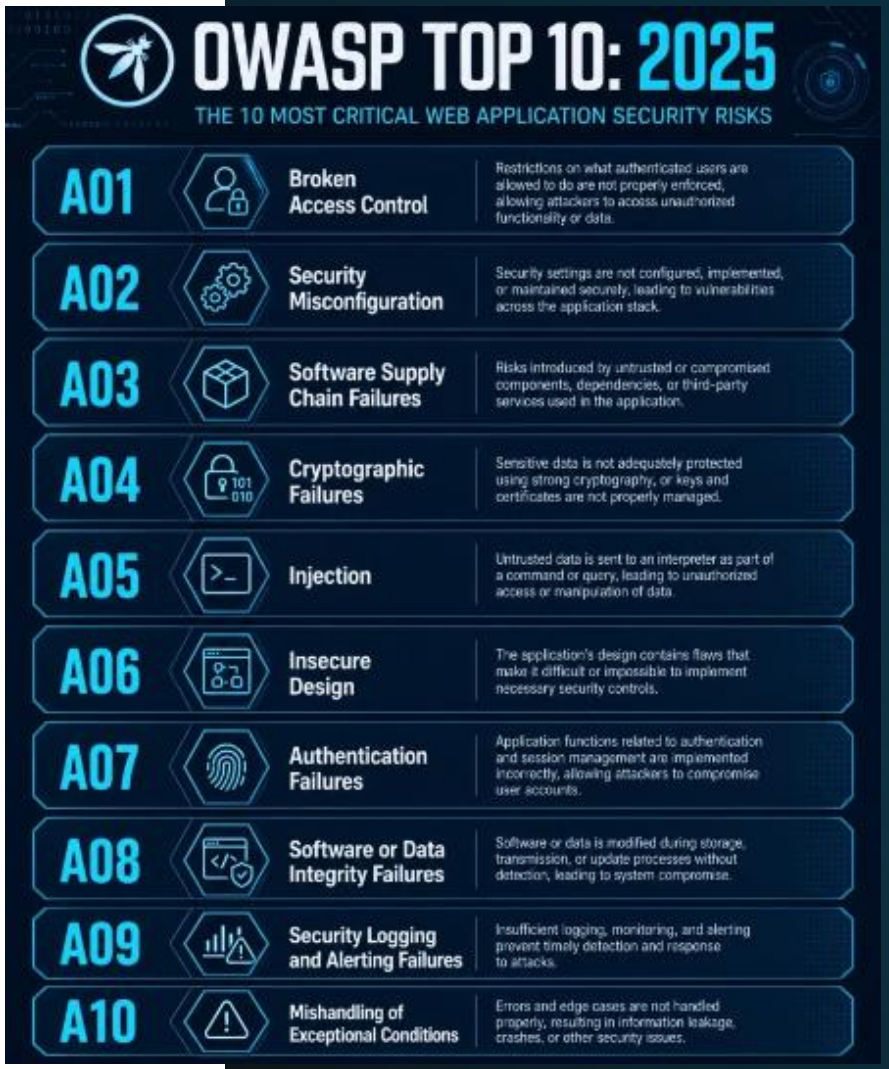


Czym jest IDOR?

IDOR (Insecure Direct Object Reference) to krytyczna podatność z grupy kontroli dostępu (Access Control). Występuje, gdy aplikacja udostępnia użytkownikowi bezpośredni identyfikator do wewnętrznego obiektu (np. numer ID w bazie danych, nazwę pliku, numer konta), ale serwer **nie weryfikuje**, czy dany użytkownik ma uprawnienia, aby ten konkretny obiekt odczytać lub zmodyfikować.

Ewolucja w OWASP: Od IDOR do BOLA

Warto wiedzieć, że w najnowszych zestawieniach bezpieczeństwa (np. OWASP API Security Top 10) termin IDOR został zastąpiony szerszym pojęciem: **BOLA (Broken Object Level Authorization)**. Oznacza dokładnie ten sam mechanizm błędu (brak weryfikacji uprawnień na poziomie obiektu), ale nazwa BOLA lepiej oddaje *przyczynę* problemu (brak autoryzacji), podczas gdy IDOR opisywał jedynie jego *objaw* (bezpośrednie odwołanie).



Anatomia ataku

Błąd ten nie wynika z braku logowania (uwierzytelniania), lecz z braku **autoryzacji na poziomie konkretnego rekordu**. Do powstania IDOR muszą być spełnione dwa warunki:

- **Bezpośrednie odwołanie**
- **Brak walidacji dostępu**

Przykłady z prawdziwego życia

01

Manipulacja parametrem w URL (GET)

02

Atak na API poprzez JSON (POST/PUT)

03

Dostęp do statycznych plików

Skutki podatności

Konsekwencje IDOR są zazwyczaj bardzo poważne, ponieważ atak ten daje się łatwo zautomatyzować (np. iterując w pętli od ID=1 do 100 000):

- **Masowy wyciek danych (Data Breach)**
- **Przejęcia kont (Account Takeover - ATO)**
- **Modyfikacja lub niszczenie danych**
- **Kary finansowe i wizerunkowe**

Jak się bronić?

Mitygacja i najlepsze praktyki:

- **Weryfikacja uprawnień (Access Control)**
- **Nieodgadywalne identyfikatory**
- **Zasada minimalnego uprzywilejowania (Zero Trust)**
- **Indirect Object References**
- **Macierze dostępu (RBAC/ABAC)**



Wykrywanie ataku

- **Technika "Dwóch Przeglądarek"**
- **Automatyzacja – trudności SAST**
- **Narzędzia klasy DAST i Proxy**



Q&A



Dziękujemy za uwagę